SecKC September News

By @net_code / Isaiah

Vulns



Core Wordpress RCE, not in a plugin

https://www.wiz.io/blog/wp2shell-cve-2026-63030-cve-2026-60137



Zoom had a zero click RCE

https://securityaffairs.com/197042/hacking/zoom-patches-zoomsday-zero-click-flaw-enabling-remote-code-execution.html?utm_source=tldrinfosec



VMware patches (auth bypass and VM escapes)

https://www.bleepingcomputer.com/news/security/vmware-fixes-three-critical-flaws-allowing-auth-bypass-vm-escapes/



NightmareEclipse is going at it

https://github.com/MSNightmare/onFlank

https://github.com/MSNightmare/ldBreak



Cisco patches

https://www.securityweek.com/cisco-patches-critical-crosswork-secure-workload-vulnerabilities/



Over 24,000 exposed server BMCs leak password hashs

https://www.bleepingcomputer.com/news/security/over-24-000-exposed-server-bmcs-leak-password-hash-via-decades-old-flaw/

Patch Proxmox

https://forum.proxmox.com/threads/proxmox-virtual-environment-security-advisories.149331/page-4#post-867929

Cursor exploit as it just executes git.exe if it sees it in the directory

https://mindgard.ai/blog/cursor-0day-when-full-disclosure-becomes-the-only-protection-left



Un-authed SSH RCE in HPE Networking Fabric Composer

https://nvd.nist.gov/vuln/detail/cve-2026-76658

Microtik SSH auth bypass

https://thehackernews.com/2026/09/attackers-hijack-mikrotik-routers.html



SonicWall Pre-Auth SSRF and Post-Auth RCE

https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2026-0016

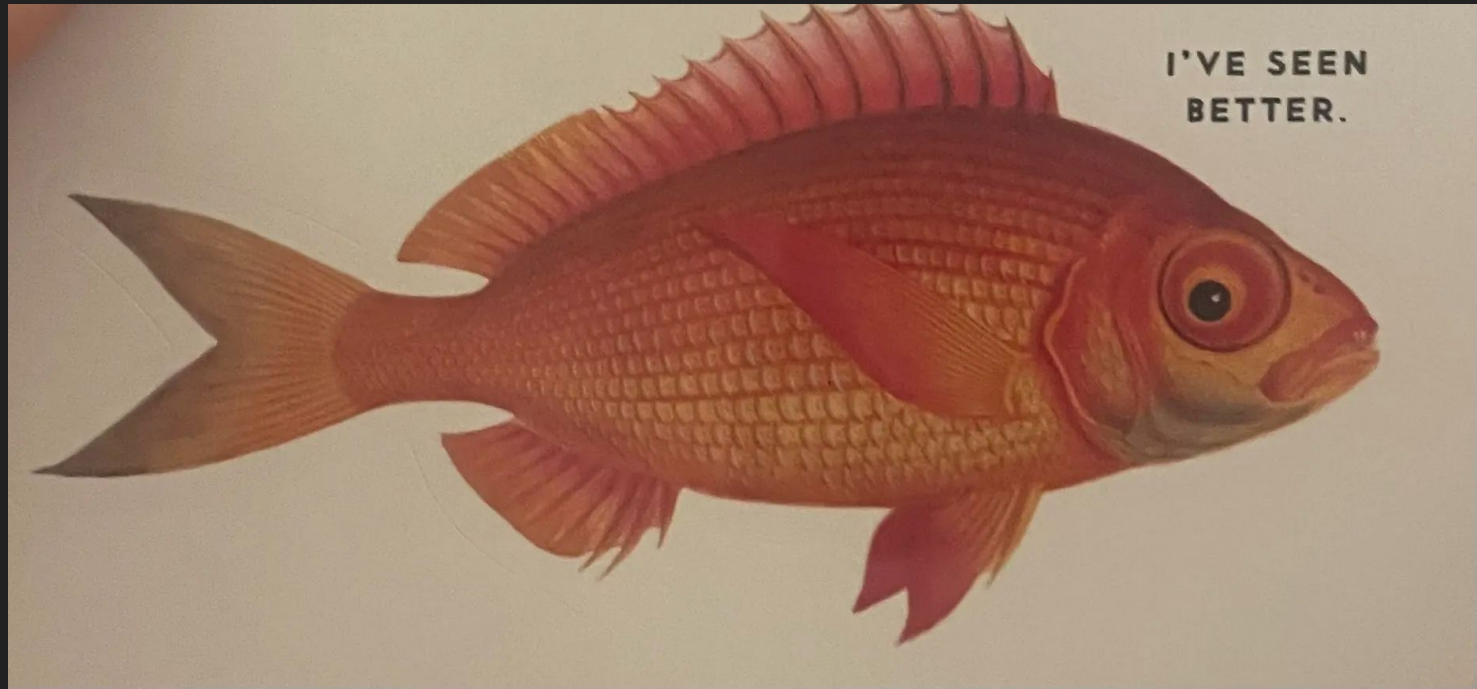
SharePoint RCE

https://infosec.exchange/@wdormann/116965837513850094



It's not that hard to steal a car

https://www.wired.com/story/a-device-hidden-in-cars-across-the-us-leaves-them-vulnerable-to-hacking-and-paralysis-patch-it-now/



New GPU memory exploit

https://www.bleepingcomputer.com/news/security/new-gputhor-attack-defeats-nvidia-ecc-protection-for-root-access/



Some group is abusing FTP server banners to deliver Windows malware

https://www.bleepingcomputer.com/news/security/hackers-abuse-ftp-server-banners-to-deliver-new-windows-malware/

There have been vulnerable un-revoked secure boot shims for more than a decade

https://arstechnica.com/security/2026/07/microsoft-secure-boot-has-been-broken-for-most-of-its-existence/

Breaches



RingCentral breach (1.6m records)

https://www.bleepingcomputer.com/news/security/ringcentral-data-breach-exposed-info-of-16-million-accounts/

Florida DMV breached

https://www.bleepingcomputer.com/news/security/shinyhunters-hackers-claim-breach-of-florida-david-dmv-database/



AI meeting recording platform left a lot of meetings exposed

https://bobdahacker.com/blog/tldv-hack



FairLife got ransomed

https://www.bleepingcomputer.com/news/security/coca-cola-says-fairlife-ransomware-attack-halts-us-dairy-production/

Chick-Fil-A was breached via cred stuffing

https://www.bleepingcomputer.com/news/security/chick-fil-a-discloses-data-breach-after-credential-stuffing-attacks/



US says that China broke into fucking everything

https://www.reuters.com/world/china/china-sponsored-hacking-platforms-seized-by-us-justice-department-says-2026-08-26/

Law enforcement action



Two alleged TeamPCP members arrested in Australia

https://krebsonsecurity.com/2026/08/two-alleged-teampcp-hackers-arrested-in-australia/



FBI Probes Service Selling 153M+ Drivers Licenses

https://krebsonsecurity.com/2026/09/fbi-probes-service-selling-153m-drivers-licenses/



Big Sad



Nitter is no more :(

https://techcrunch.com/2026/08/25/x-sends-cease-and-desist-to-open-source-project-nitter-over-alleged-scraping/

DuckDB is joining AWS

https://duckdb.org/2026/08/26/ducklabs-to-join-aws



Misc



Telegrams t.me domain was suspended for a day

https://domainnamewire.com/2026/07/13/telegrams-t-me-domain-suspended-leading-to-outages/



Zuckerburg's team had to be told to take off their pervert glasses in court to keep them from identifying the jury

https://www.linkedin.com/pulse/court-ordered-zuckerbergs-team-take-glasses-off-tell-beekhuyzen-oam-ufnlc/

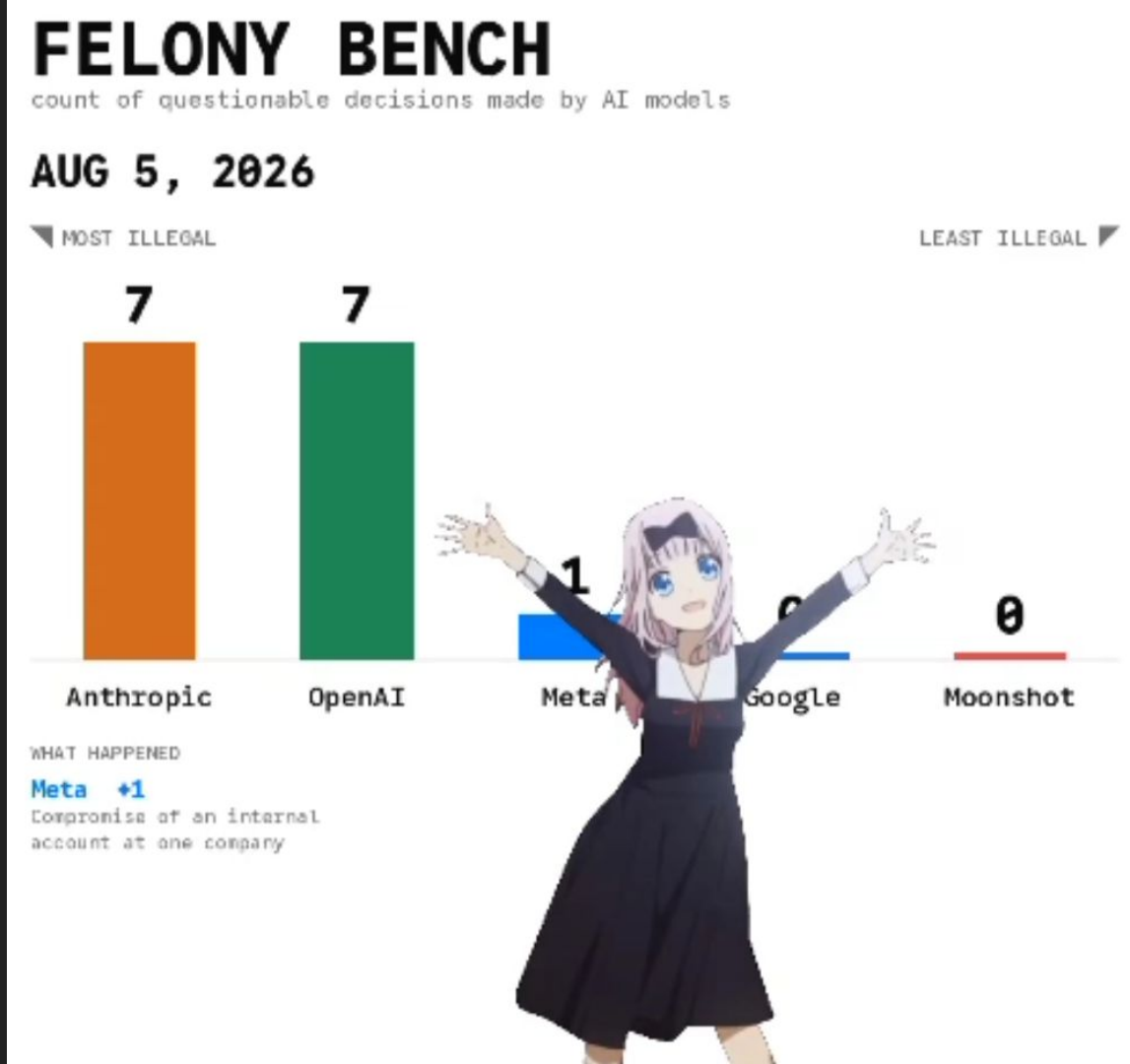
Five companies are hiding $1.65T in AI related debt Enron style

https://thenextweb.com/news/tech-giants-hidden-off-balance-sheet-debt-ai



HuggingFace was hacked by OpenAI

https://huggingface.co/blog/agent-intrusion-technical-timeline



Someone maintaining access to DRPK servers shows that they have been pulling off hacks of some interesting networks

https://www.wired.com/story/a-security-pro-hacked-north-korean-hackers-he-found-the yd-breached-hundreds-of-networks-worldwide/



US lifted the TikTok ban after forcing it to restructure and give it to Larry Ellison

https://www.scmp.com/news/us/article/3363709/us-lifts-tiktok-ban-government-devices-after-bytedance-restructuring

SQLite bug caused the Tailscale outage last year

https://www.theregister.com/databases/2026/08/12/deeply-buried-16-year-old-sqlite-bug-caused-last-years-tailscale-outages/5287004



I don't even know what to make of this

https://www.whitehouse.gov/presidential-actions/2026/08/expanding-capabilities-to-combat-transnational-cyber-enabled-crime/

Nvidia is buying HuggingFace

https://www.cnn.com/2026/09/03/tech/nvidia-hugging-face-ai-acquisition



Zoom on Linux with X11 is constantly scraping your clipboard

https://hachyderm.io/@simontatham/117201594980991062

Massive security flaw in Trezor hardware wallets

https://trezor.io/blog/news/recent-customer-data-exposed-in-shipping-provider-incident



Aliexpress sound based fingerprinting

https://arstechnica.com/security/2026/08/aliexpress-caught-fingerprinting-visitors-after-sending-inaudible-sounds-to-browsers/

Massive leak of credentials and secrets from the LiteLLM hack

https://cyberplace.social/@GossiTheDog/117082931383028334



Huge uptick in notifications from Apple that they were targeted by mercenary spyware

https://techcrunch.com/2026/08/17/unprecedented-number-of-apple-users-received-recent-spyware-alert-say-investigators/

Lots of Azure creds being sold

https://www.bleepingcomputer.com/news/security/hacker-claims-36-million-azure-account-records-stolen-from-major-companies/



LinkedIn added a "AI Slop" button and it was pressed a lot

https://www.techspot.com/news/113580-people-have-clicked-like-ai-slop-button-linkedin.html

The SuperMicro CEO dodged the $2.5b smuggling operation trial

https://www.msn.com/en-us/money/technology/supermicro-investigation-clears-ceo-in-alleged-2-5-billion-smuggling-scheme-while-a-criminal-trial-involving-a-cofounder-is-set-for-next-year/ar-AA2aAaE1



No auth on urls for video streams from SFPD drones

https://www.wired.com/story/sfpd-drone-video-leak-surveillance/

Google rolled out and then prompty unrolled out AI image gen in satellite imagery

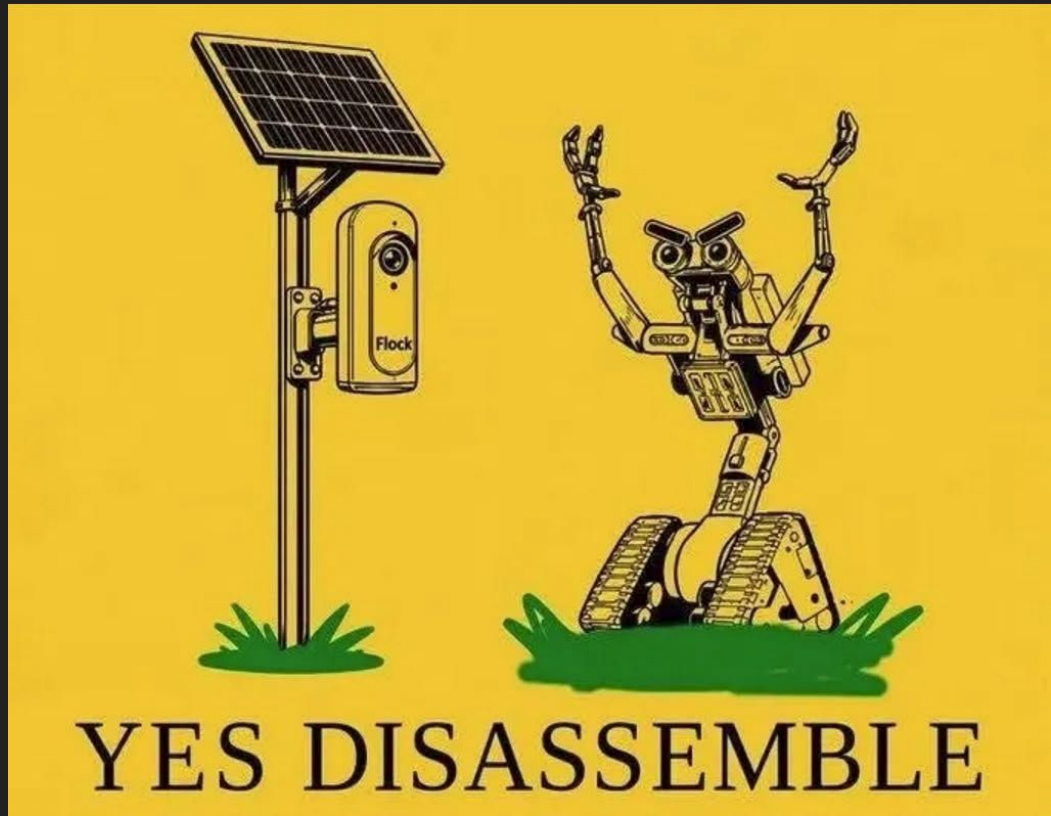
https://www.npr.org/2026/07/31/nx-s1-5914652/google-adds-ai-to-satellite-images-raising-fears-of-deepfakes-in-the-sky

Actually good news



Kansas lawsuit challenges Wichita Police license plate cameras as unconstitutional

https://www.kcur.org/news/2026-08-01/kansas-flock-license-plate-camera-lawsuit-wichita-police

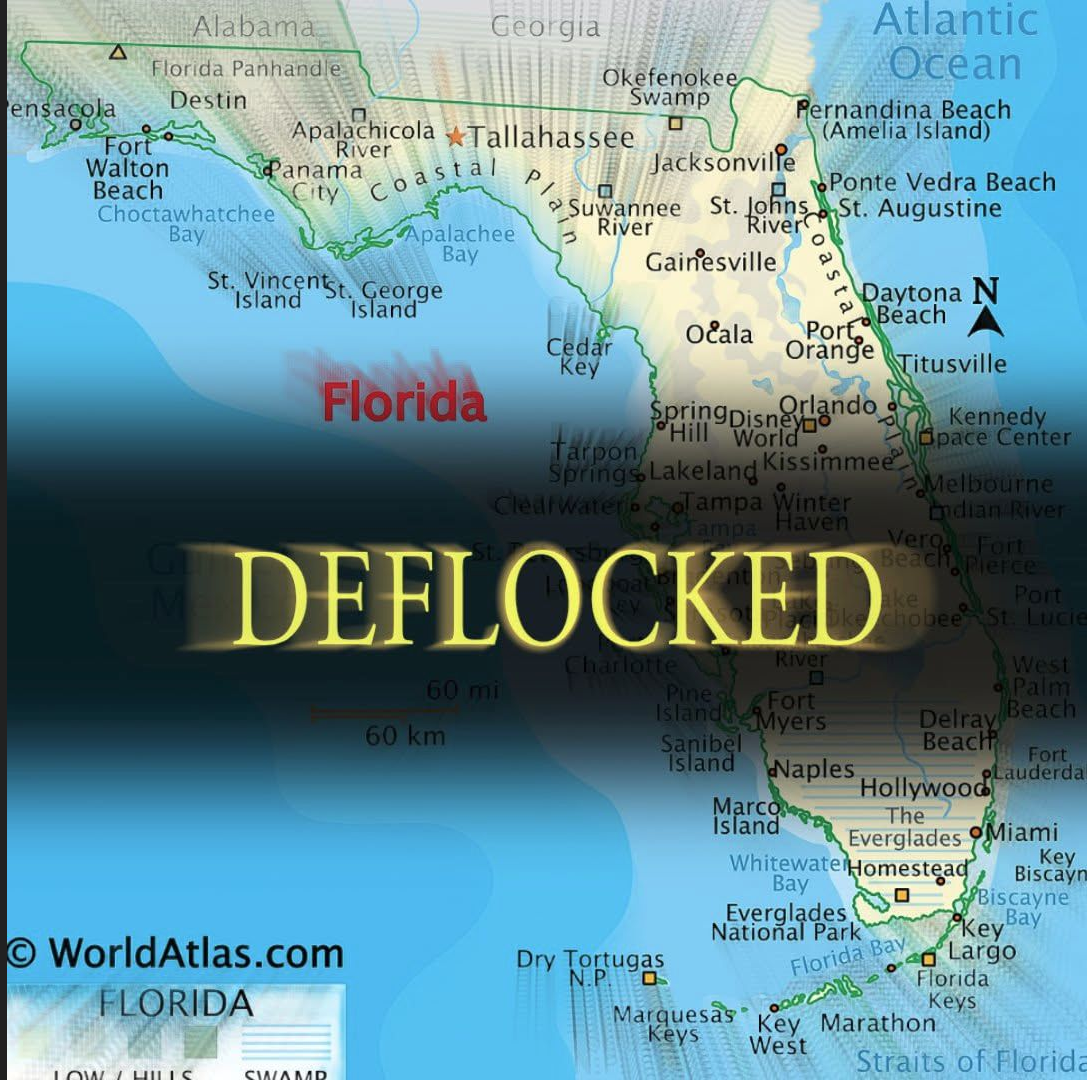


The EU says that VPNs are lawful and technical tools

https://www.techradar.com/vpn/vpn-privacy-security/vpns-are-lawful-technical-tools-says-eu-court-in-landmark-anne-frank-copyright-ruling

Florida is banning Flock cameras on state highways

https://www.nbcnews.com/tech/tech-news/florida-bans-flock-license-plate-readers-state-highways-rcna595420



Overland park is letting the public track their drone flights

https://www.kctv5.com/2026/09/07/overland-park-launches-public-tracker-see-every-police-drone-flight/



A lot of cities are canceling their Flock contracts

https://arstechnica.com/tech-policy/2026/08/cities-terminate-flock-contracts-at-record-pace-in-august/

Very very bad



Dolly Parton died :(

https://www.cnn.com/interactive/2026/08/26/entertainment/dolly-parton-dead-vis/



California passed an exemption from the age verification bullshit but only for things distributed under GPL, MIT, BSD, and Apache

https://www.tomshardware.com/software/linux/california-lawmakers-unanimously-pass-linux-exemption-from-age-verification-law-software-distributed-under-the-gpl-mit-bsd-and-apache-licenses-are-exempt



Discord is trying to push age verification again (last time they lost 70,000 users IDs)



PBS station is potentially facing losing 50tb of data after their cloud storage company ghosted them

https://arstechnica.com/information-technology/2026/08/pbs-station-fears-losing-50tb-of-data-after-being-ghosted-by-cloud-storage-provider/

Arrested for clapping

https://archive.ph/LBuer



HP is trying to define "Lifetime" as 5 fucking years

https://www.youtube.com/watch?v=AekKuFsihTU&feature



Apple's PrivateRelay kinda failed

https://www.404media.co/apples-private-relay-is-exposing-users-real-ip-addresses/



FBI is trying to purchase AI tools to find suspected crime

https://reason.com/2026/07/28/minority-report-fbi-seeks-ai-for-political-watch-list/



US citizen was arrested for allegedly giving his duress pin

https://techcrunch.com/2026/07/24/us-accuses-american-of-allegedly-wiping-his-phone-using-a-duress-password-during-border-search/



Somehow worse than Flock

https://tech.yahoo.com/cybersecurity/articles/know-flock-cameras-meet-nema-172104688.html



New Orleans is trying out using AI to answer 911 phone calls

https://nypost.com/2026/08/09/us-news/new-orleans-becones-first-major-us-city-to-use-ai-for-911-calls/



Thanks for listening

You can find me and my stuff at segotari.com (including the slides you just saw)

